HUST

TRƯỜNG ĐẠI HỌC BÁCH KHOA HÀ NỘI

HANOI UNIVERSITY OF SCIENCE AND TECHNOLOGY

ONE LOVE. ONE FUTURE.

TRƯỜNG ĐẠI HỌC
BÁCH KHOA HÀ NỘI
HANOI UNIVERSITY
OF SCIENCE AND TECHNOLOGY

LÝ THUYẾT MẬT MÃ

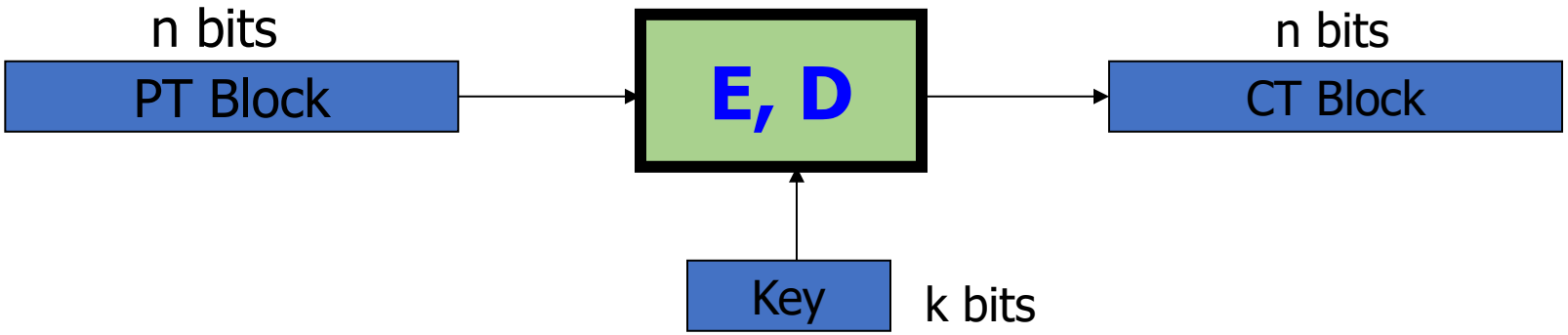
TS. TẠ KIM HUỆ
TRƯỜNG ĐIỆN – ĐIỆN TỬ

ONE LOVE. ONE FUTURE.

Nội dung

- Khái niệm PRP và PRF bảo mật
- Các chế độ sử dụng mã khối : Khoá dùng 1 lần
- Các chế độ sử dụng mã khối: Khoá dùng nhiều lần

Block ciphers: crypto work horse



Canonical examples:

1. 3DES: n= 64 bits, k = 168 bits
2. AES: n=128 bits, k = 128, 192, 256 bits

Tóm tắt: Khái niệm PRPs và PRFs

- Pseudo Random Function (**PRF**) hàm giả ngẫu nhiên được định nghĩa qua tập (K,X,Y): F: $K \times X \rightarrow Y$, do đó tồn tại một thuật toán hiệu quả để đánh giá F(k,x)
- Pseudo Random Permutation (**PRP**) là một hoán vị giả ngẫu nhiên E: $K \times X \rightarrow X$

Do đó:

1. Tồn tại một thuật toán hiệu quả xác định ("efficient" <u>deterministic</u> algorithm) để đánh giá được E(k,x)

2. Hàm E(k, ·) là một song ánh (one-to-one)

3. Tồn tại thuật toán nghịch đảo hiệu quả ("efficient" inversion algorithm) D(k,x)

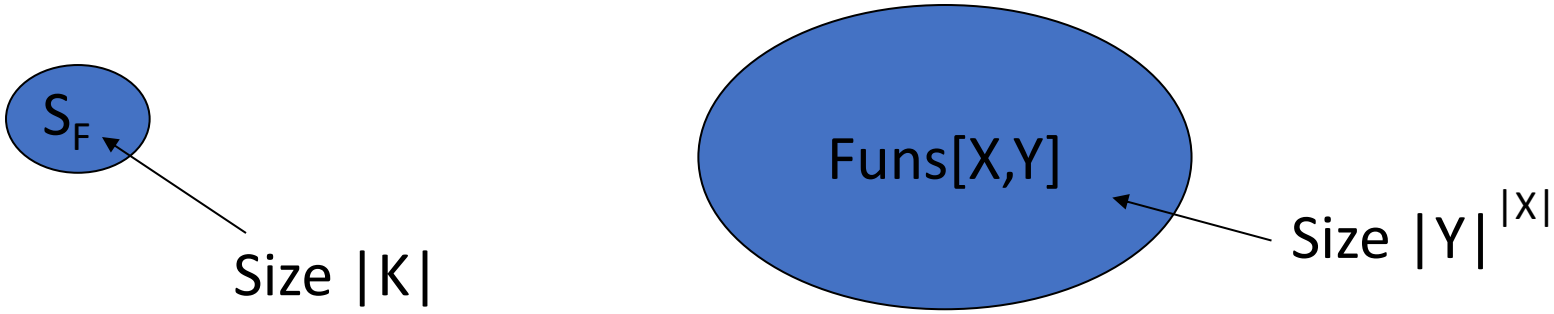
PRFs bảo mật (Secure PRFs)

- Cho $F: K \times X \rightarrow Y$ là một PRF

  Funs[X,Y]: là tập các hàm từ X thành Y

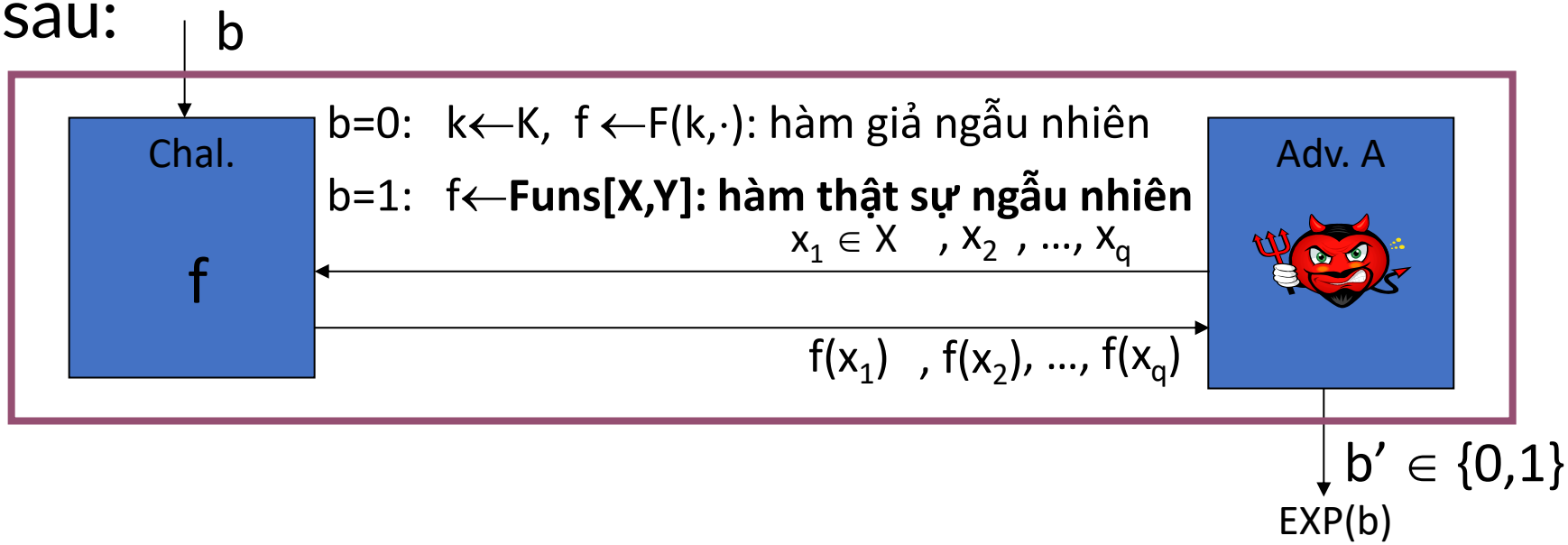
  $S_F = \{ F(k,\cdot) \text{ s.t. } k \in K \} \subseteq \text{Funs}[X,Y]$

- <u>Intuition</u>: a PRF is **secure** if
  Một hàm ngẫu nhiên trong Funs[X,Y] là không thể phân biệt với một hàm ngẫu nhiên trong S_F



Secure PRF: definition

- Cho b=0,1 định nghĩa phép kiểm định EXP(b) như sau:



- Định nghĩa: F là một hàm PRF bảo mật nếu mọi thuật toán hiệu quả A có độ lợi thế:

$$Adv_{PRF}[A,F] := \left| Pr[EXP(0)=1] - Pr[EXP(1)=1] \right|$$

là một giá trị "không đáng kể " (negligible)

Secure PRF: definition

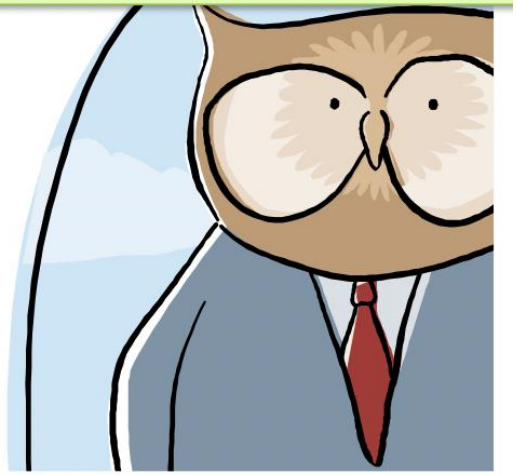
security parameter
n

Scenario 0 : EXP(0)

Scenario 1 : EXP(1)

distinguisher D

challenger
chooses a random **k** $\in \{0,1\}^n$.



$x_1 \in \{0,1\}^u$ →

← $F_k(x_1)$

$x_2 \in \{0,1\}^u$ →

← $F_k(x_2)$

⋮

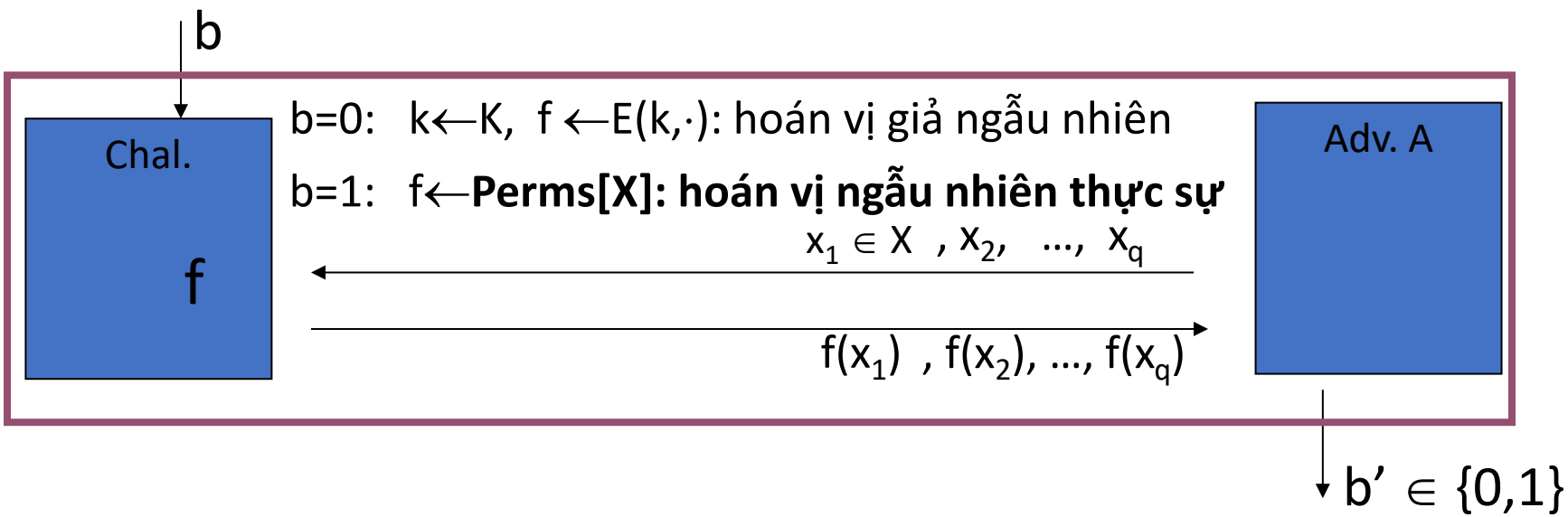
$x_t \in \{0,1\}^u$ →

← $F_k(x_t)$

$$\mathrm{Adv}_{PRF}[A,F] := \left| \Pr[EXP(0)=1] - \Pr[EXP(1)=1] \right|$$

PRP bảo mật - Secure PRP (secure block cipher)

- Cho b=0,1 giá trị thực nghiệm EXP(b) được xác định như sau:



- Định nghĩa: E là một hoán vị bảo mật PRP nếu mọi thuật toán hiệu quả có lợi thế được tính như sau:

$$Adv_{PRP}[A,E] = |Pr[EXP(0)=1] - Pr[EXP(1)=1]|$$

là một giá trị không đáng kể

Ví dụ về PRP bảo mật

- Cho $X = \{0,1\}$. Perms[X] chứa 2 hàm
- Xem xét PRP sau đây: key space $K=\{0,1\}$, input space $X = \{0,1\}$, PRP defined as: $E(k,x) = x \oplus k$
- Đây có phải PRP bảo mật ?

  → Yes

  No

  It depends

Attacker A:

(1) query $f(\cdot)$ at $x=0$ and $x=1$

$Adv_{PRF}[A,E] = |1/2 - 1/2| = 0$

<u>PRPs believed to be secure</u>: 3DES, AES, …

AES-128: $K \times X \rightarrow X$ where $K = X = \{0,1\}^{128}$

An example concrete assumption about AES:

All 2^{80}–time algs. A have $Adv_{PRP}[A, \mathbf{AES}] < 2^{-40}$

Ví dụ về PRF bảo mật

- Consider the 1-bit PRP from the previous question: $E(k,x) = x \oplus k$
- Is it a secure PRF?
- Note that Funs[X,X] contains four functions

Yes

No

It depends

Attacker A:
(1) query $f(\cdot)$ at $x=0$ and $x=1$
(2) if $f(0) = f(1)$ output "1", else "0"
$Adv_{PRF}[A,E] = |0-½| = ½$

Các chế độ sử dụng mã khối

Khoá dùng 1 lần (one time key)

Using PRPs and PRFs

Mục tiêu: tạo một mã bảo mật từ PRP bảo mật (e.g. AES).

This segment: **Các khoá 1 lần (one-time keys)**

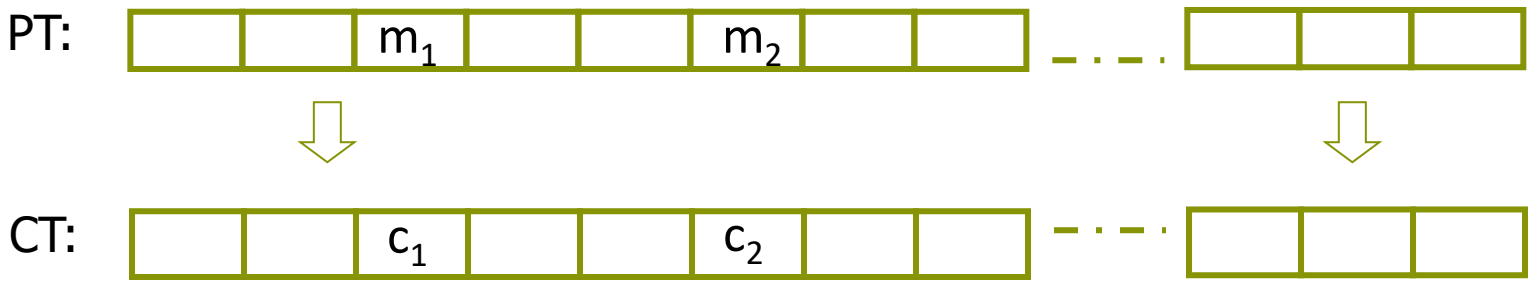
1. Adversary's power: Adv có được một ciphertext (one-time key)

2. Adversary's goal: khám phá về PT từ CT (semantic security)

Next segment: many-time keys (a.k.a chosen-plaintext security)

Cách sử dung sai một PRP

Electronic Code Book (ECB):



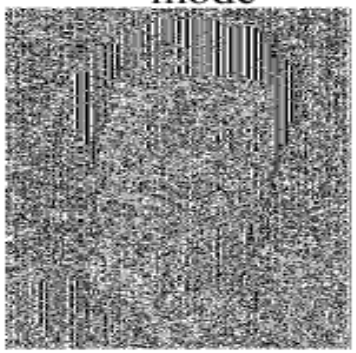
Problem:

- if $m_1=m_2$ then $c_1=c_2$

In pictures

An example plaintext

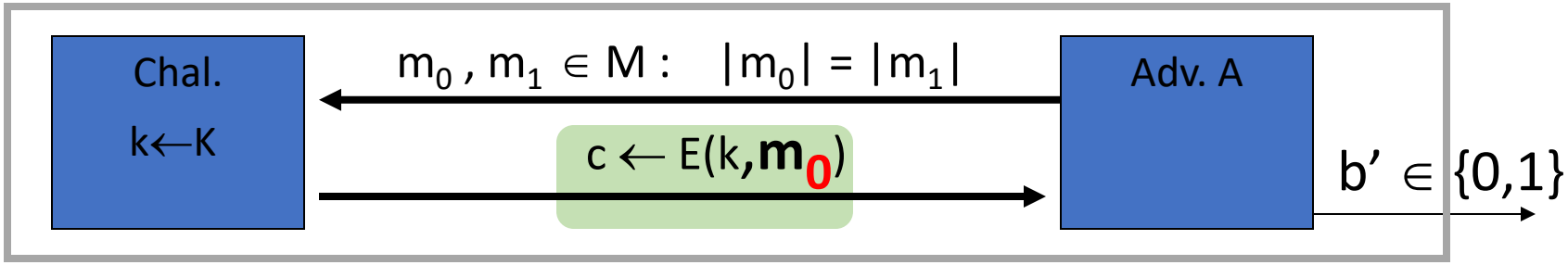
Encrypted with AES in ECB mode



(courtesy B. Preneel)

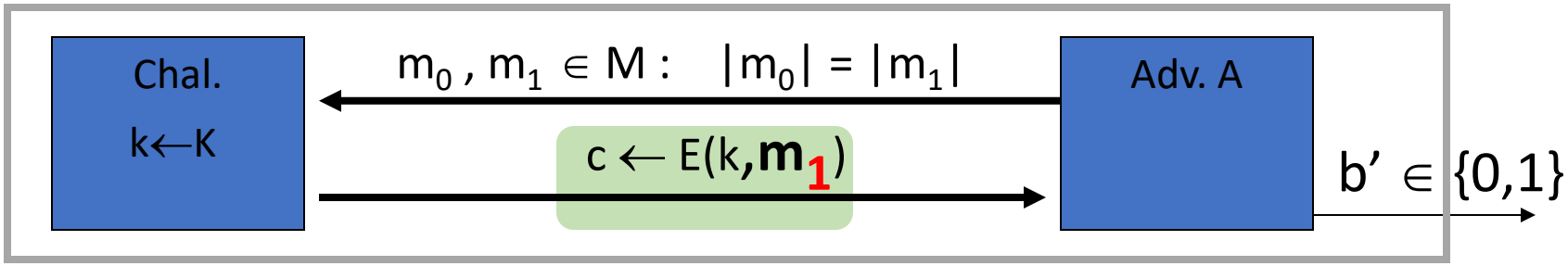
Bảo mật ngữ nghĩa -Semantic Security (one-time key)

EXP(0):



one time key ⇒ adversary sees only one ciphertext

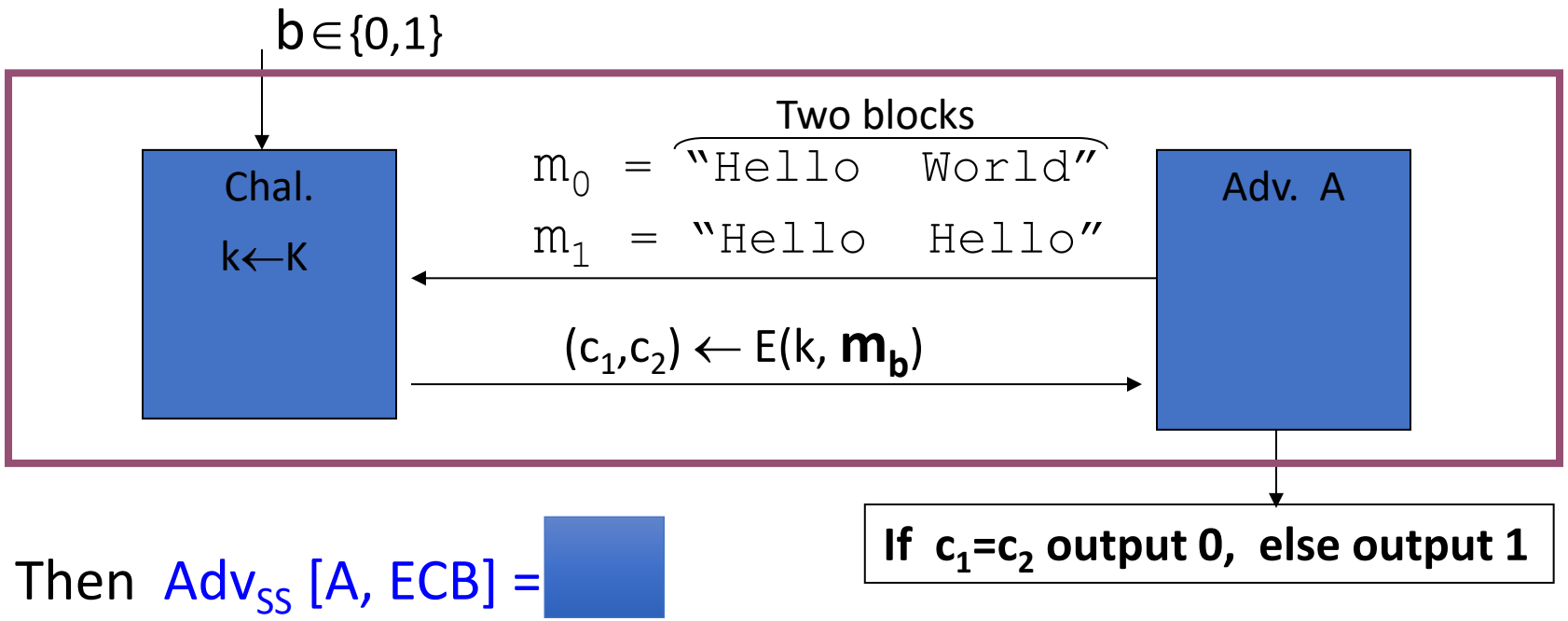
EXP(1):



$\mathrm{Adv}_{SS}[A,OTP] = \left| \Pr[\ \mathbf{EXP(0)}=1\ ] - \Pr[\ \mathbf{EXP(1)}=1\ ] \right|$ should be "neg."

ECB is not Semantically Secure

ECB là không bảo mật ngữ nghĩa đối với những thông điệp chứa nhiều hơn 1 khối.



Then Adv_{SS} [A, ECB] =

Các chế độ sử dung mã khối

Bảo mật với khoá dùng nhiều lần

1. File systems: Same AES key used to encrypt many files.
2. IPsec: Same AES key used to encrypt many packets.

Semantic Security với khoá dùng nhiều lần (many-time key)

Khoá sử dung nhiều lần ⇒ adv. Có được nhiều CTs với cùng 1 khoá

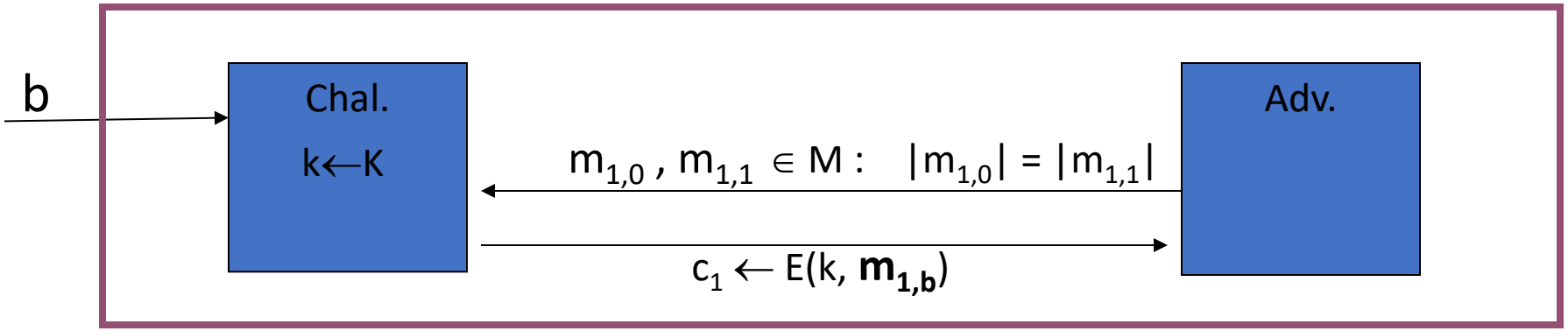
Adversary's power: chosen-plaintext attack (CPA)

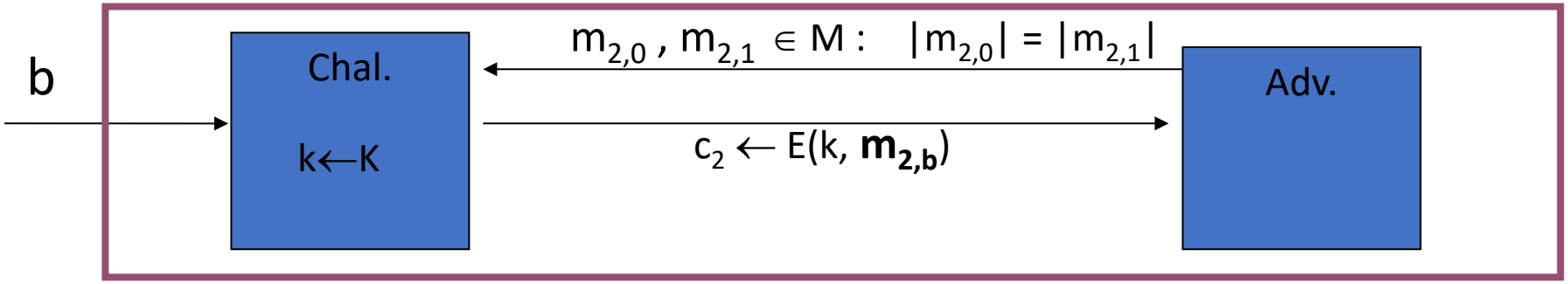
- Có thể có được các bản mã hoá của các bản tin đầu vào được lựa chọn (conservative modeling of real life)

Adversary's goal: phá vỡ sematic security

Semantic Security for many-time key

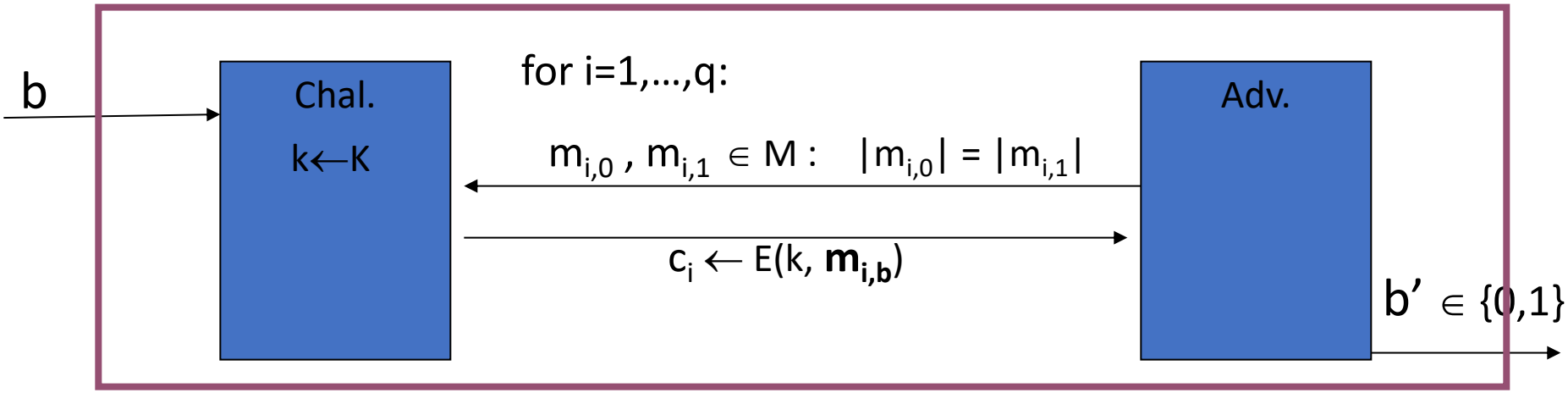
$\mathbb{E}$ = (E,D) a cipher defined over (K,M,C). For b=0,1 define EXP(b) as:





Semantic Security for many-time key (CPA security)

$\mathbb{E}$ = (E,D) a cipher defined over (K,M,C). For b=0,1 define EXP(b) as:

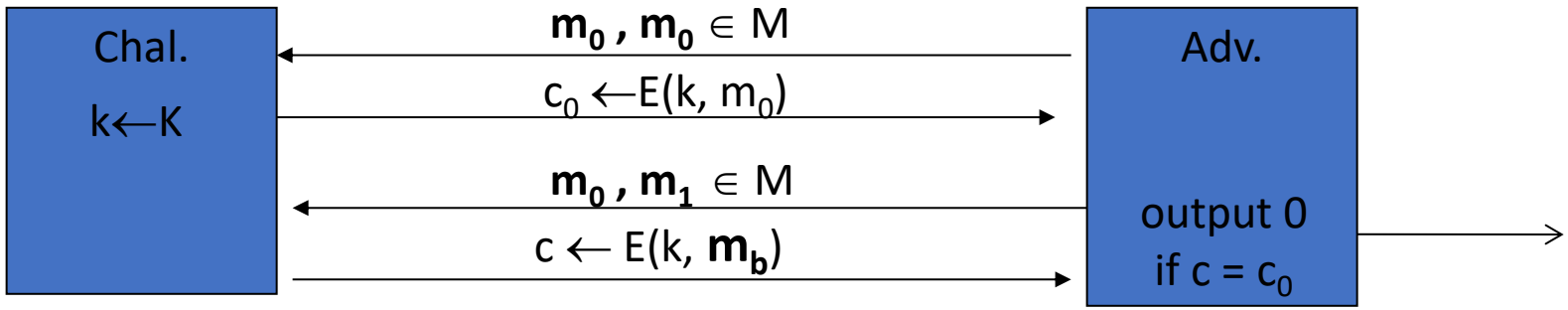


if adv. wants c = E(k, m) it queries with $m_{j,0} = m_{j,1} = m$

Def: $\mathbb{E}$ is sem. sec. under CPA if for all "efficient" A:
$Adv_{CPA}[A,\mathbb{E}] = |\Pr[EXP(0)=1] - \Pr[EXP(1)=1]|$ is "negligible."

Bản mã không bảo mật dưới tấn công CPA

Giả sử E(k,m) luôn có đầu ra như nhau (same ciphertext) với bản tim m. Do đó:

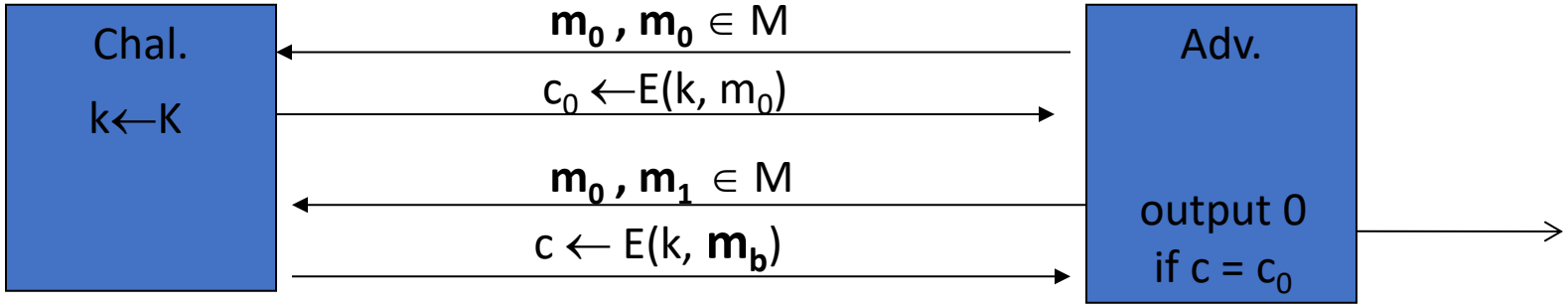


So what? Kẻ tấn công có thể học được khi nào thì 2 file được mã hoá là như nhau, hai gói tin được mã hoá là như nhau, etc.

Dẫn tới các tấn công đáng kể khi không gian bản mã M là quá nhỏ

Bản mã không bảo mật dưới tấn công CPA

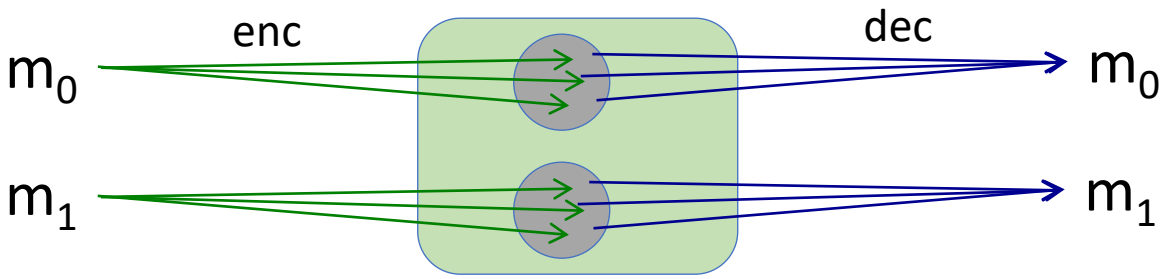
Suppose E(k,m) always outputs same ciphertext for msg m. Then:



Nếu khoá bí mật được sử dụng nhiều lần ⇒ đưa vào cùng 1 plaintext nhưng sẽ tạo ra những bản mã khác nhau.

Giải pháp 1: Hàm mã hoá ngẫu nhiên (randomized encryption)

- E(k,m) là một thuật toán ngẫu nhiên:



⇒ encrypting same msg twice gives different ciphertexts (w.h.p)

⇒ ciphertext must be longer than plaintext

Roughly speaking: CT-size = PT-size + "# random bits"

Cho $F: K \times R \longrightarrow M$ là một PRF bảo mật.

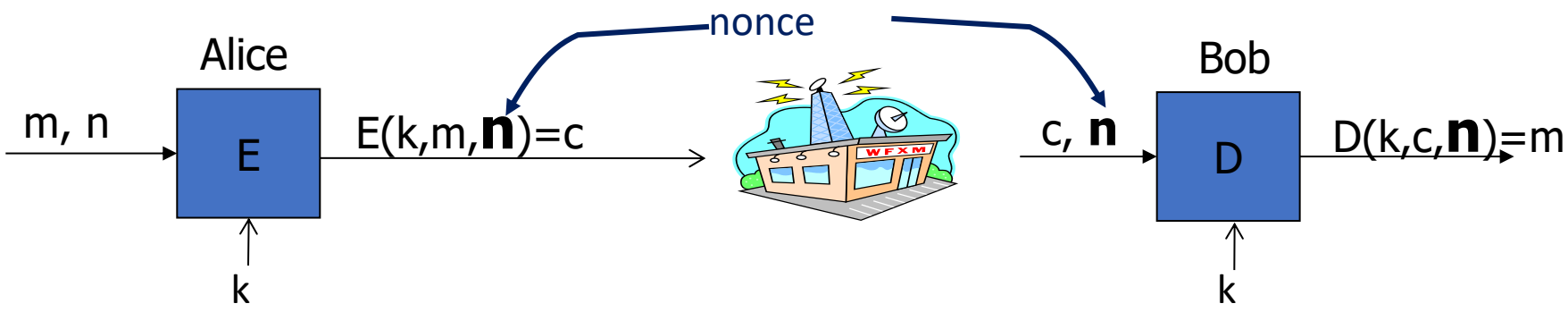
Cho $m \in M$, với $E(k,m) = [\, r \xleftarrow{R} R,\ \text{output } (r, F(k,r) \oplus m) \,] \approx_p [r, F(r) \oplus m]$

E bảo mật ngữ nghĩa dưới tấn công CPA?

- Yes, whenever F is a secure PRF
- No, there is always a CPA attack on this system
- ➡ Yes, but only if R is large enough so r never repeats (w.h.p)
- It depends on what F is used

Giải pháp 2: Mã hoá dựa trên số Nonce (nonce-based Encryption)

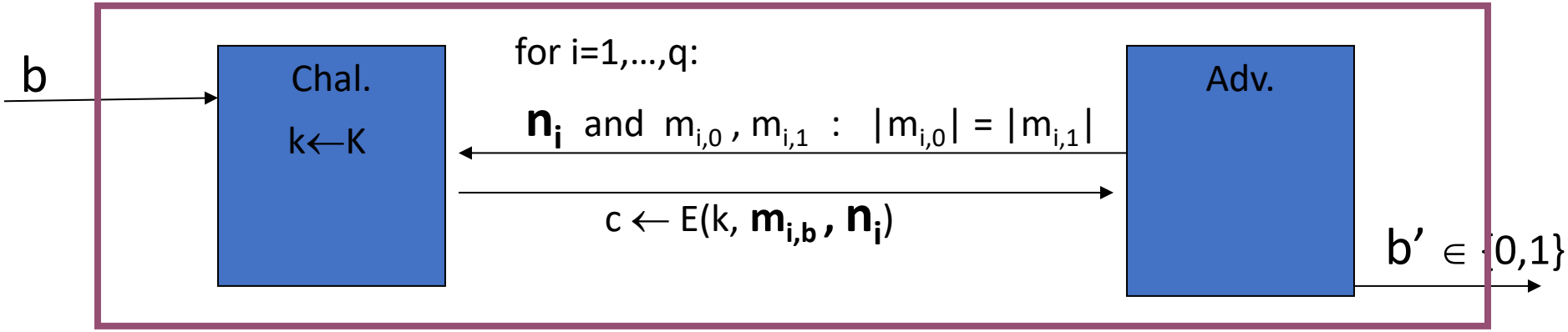
- nonce n: là một giá trị có thể thay đổi từ msg tới msg, cặp (k,n) không bao giờ sử dụng hơn 1 lần (pair <u>never</u> used more than once)



- <u>method 1</u>: nonce is a **counter** (e.g. packet counter)
  - used when encryptor keeps state from msg to msg
  - if decryptor has same state, need not send nonce with CT
- <u>method 2</u>: encryptor chooses a **random nonce**, $n \leftarrow \mathcal{N}$

CPA security for nonce-based encryption

System should be secure when nonces are chosen adversarially.



Tất cả số nonces $\{n_1, \ldots, n_q\}$ phải riêng biệt

Def: nonce-based $\mathbb{E}$ is sem. sec. under CPA if for all "efficient" A: $Adv_{nCPA}[A,\mathbb{E}] = |Pr[EXP(0)=1] - Pr[EXP(1)=1]|$ is "negligible."

Let $F: K \times R \longrightarrow M$ be a secure PRF. Let $r = 0$ initially.

For $m \in M$ define $E(k,m) = [\ r{+}{+},\ \text{output}\ (r, F(k,r) \oplus m)\ ]$

$$\approx_p [r, F(r) \oplus m]$$

Is E CPA secure nonce-based encryption?

Yes, whenever F is a secure PRF

No, there is always a nonce-based CPA attack on this system

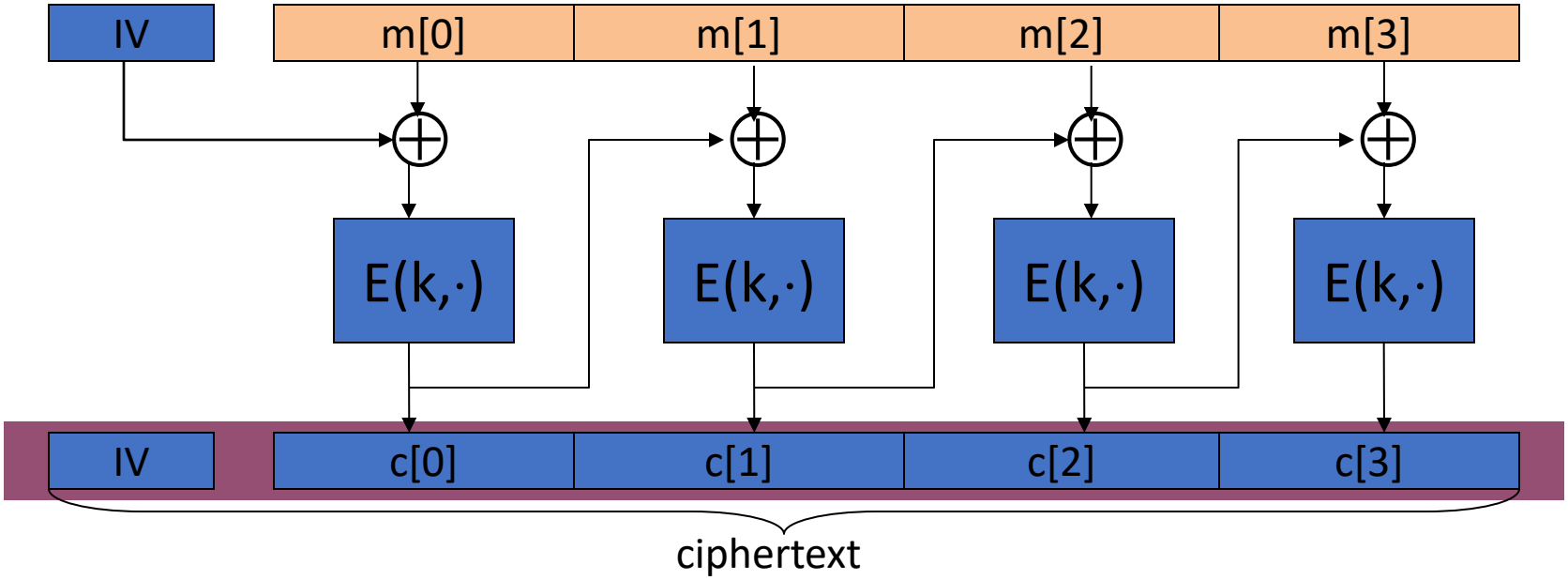
➡ Yes, but only if R is large enough so r never repeats

It depends on what F is used

Cấu trúc 1: CBC with random IV

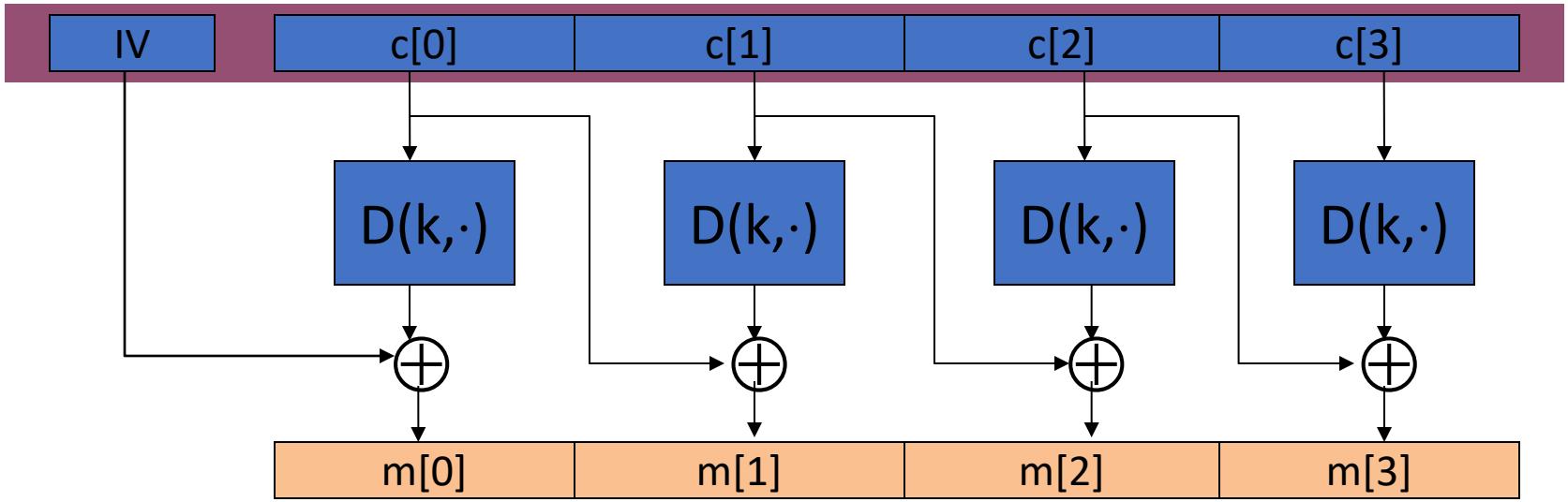
Let (E,D) be a PRP. $E_{CBC}(k,m)$: choose **random** IV∈X and do: $\mathrm{IV} \in [0,1]^n$

E: $\mathrm{K} \times [0,1]^n \rightarrow [0,1]^n$



Mạch giải mã (Decryption circuit)

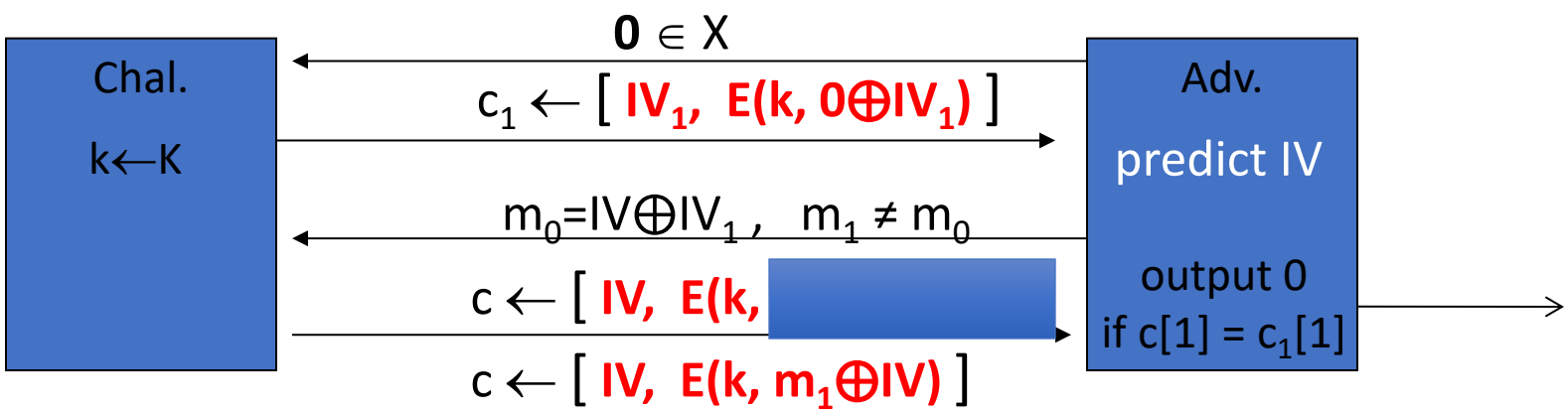
In symbols: $c[0] = E\big(k, IV \oplus m[0]\big) \quad \Rightarrow \quad m[0] =$



Warning: an attack on CBC with rand. IV

CBC where attacker can predict the IV is not CPA-secure !! (khi kẻ tấn công có thể dự đoán được IV)

Suppose given $c \leftarrow E_{CBC}(k,m)$ can predict IV for next message

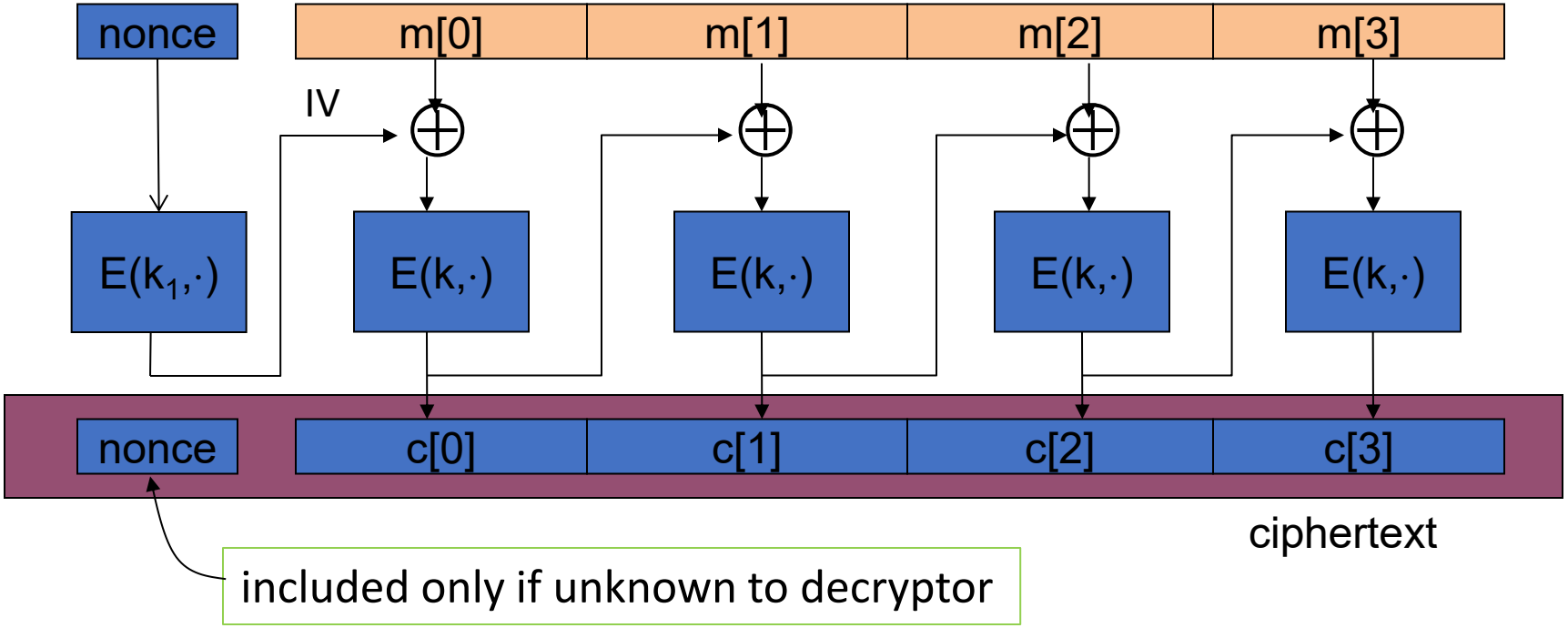


Bug in SSL/TLS 1.0: IV for record #i is last CT block of record #(i-1)

Cấu trúc 1': nonce-based CBC

- Cipher block chaining with <u>unique</u> nonce: key = (k,k_1)

unique nonce means: (key, n) pair is used for only one message



An example Crypto API (OpenSSL)

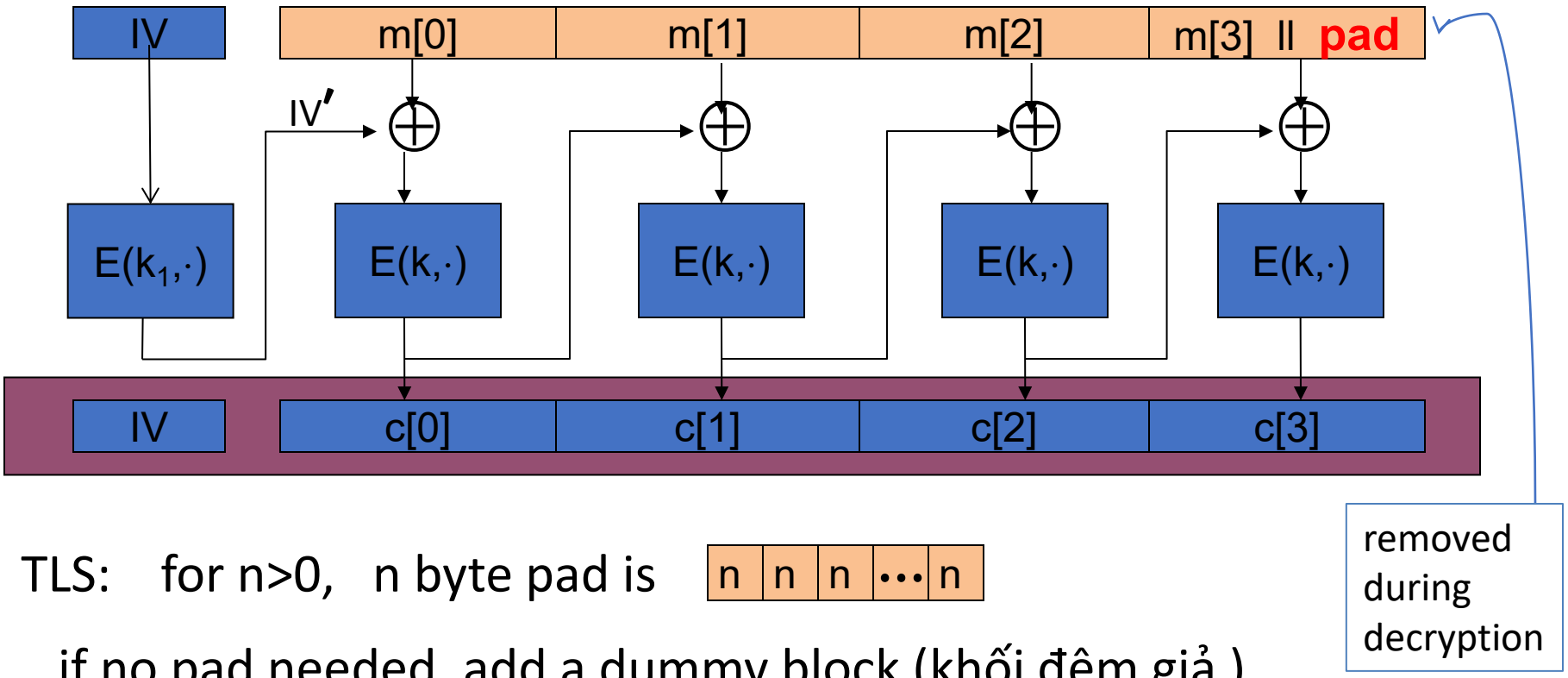
```
void AES_cbc_encrypt(
        const unsigned char *in,
        unsigned char *out,
        size_t length,
        const AES_KEY *key,
        unsigned char *ivec,
        AES_ENCRYPT or AES_DECRYPT);
```

← **user supplies IV**

Otherwise, no CPA security

When nonce is non random need to encrypt it before use

A CBC technicality: padding



TLS: for n>0, n byte pad is

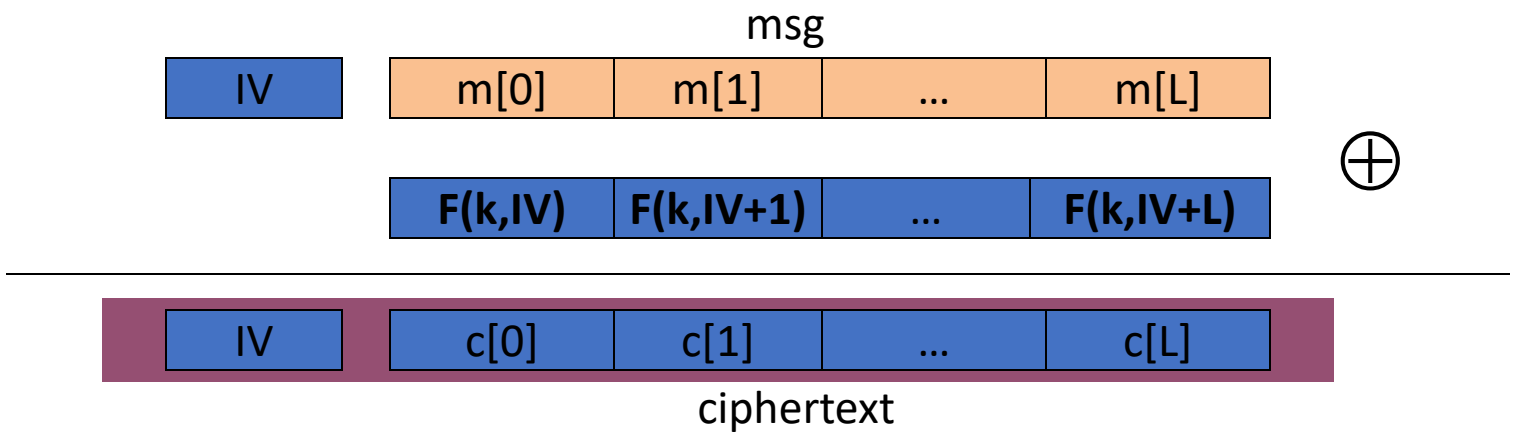
n	n	n	•••	n

if no pad needed, add a dummy block (khối đệm giả)

Cấu trúc 2: rand ctr-mode

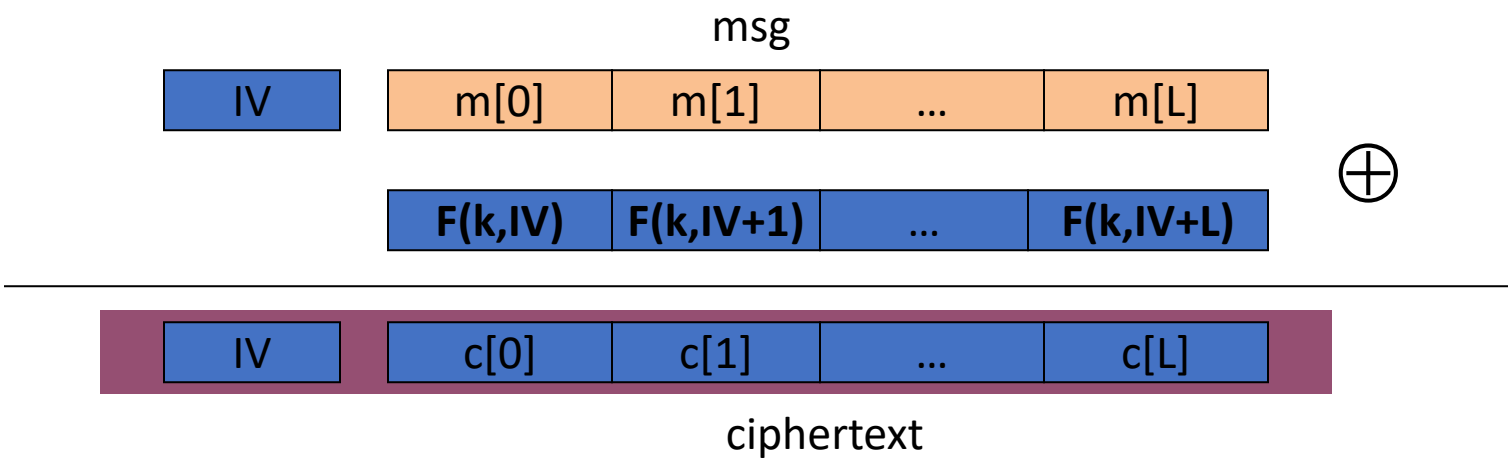
Let $F: K \times \{0,1\}^n \longrightarrow \{0,1\}^n$ be a secure PRF.

E(k,m): choose a random $IV \in \{0,1\}^n$ and do:

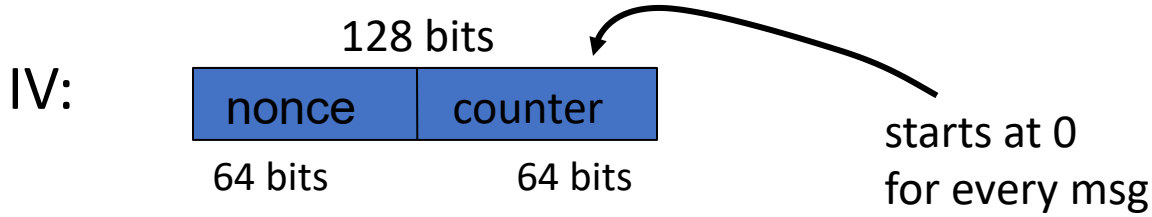


note: parallelizable (unlike CBC)

Cấu trúc 2': nonce ctr-mode



To ensure F(k,x) is never used more than once, choose IV as:



Comparison: ctr vs. CBC

	CBC	ctr mode
uses	PRP	PRF
parallel processing	No	Yes
Security of rand. enc.	q^2 L^2 << |X|	q^2 L << |X|
dummy padding block	Yes	No
1 byte msgs (nonce-based)	16x expansion	no expansion

(for CBC, dummy padding block can be solved using ciphertext stealing)